Rapport d'incident de sécurité

Exfiltration de la base clients par le compte c_dupont

Référence	INC-2026-11-06-001 (case Kibana « Exfiltration de la base clients par le compte c_dupont (6/11, 18:16) »)
Organisation	Azur Bank, SOC (groupe 3, projet SOC RUN, ESGI 5A), SIEM Elastic Security on-prem
Destinataires	RSSI, DPO, responsable conformité (PCI DSS, SWIFT CSP), direction des risques
Rédaction / validation	Analyste N2 du SOC / RSSI
Date du rapport	6 novembre 2026, version 1.0
Diffusion	Confidentiel, interne. À archiver au moins 12 mois avec les preuves (PCI DSS 10.5.1)
Statut	Clos. Incident d'exercice rejoué sur le lab, les comptes ont été remis en service après l'exercice

1. Résumé exécutif

Le 6 novembre 2026 à 18:16, le compte de base de données c_dupont, utilisé par un conseiller clientèle, a lu puis exporté en une seule session la totalité de la table des clients : 5 000 fiches avec nom, IBAN et solde [P1]. Le SIEM a détecté l'enchaînement 15 secondes après l'export [P2]. Le SOAR a ensuite bloqué l'accès à la base et désactivé le compte Windows du conseiller, 50 secondes après la première alerte et sans intervention humaine [P3][P4]. Aucune donnée n'est sortie vers Internet depuis la base, mais l'export est arrivé sur le serveur d'administration (bastion), d'où il faut encore le tracer [P5]. Statut : clos. Décision demandée : valider la notification à la CNIL (données personnelles de 5 000 clients) et imposer le second facteur sur le bastion.

2. Classification

Critère	Valeur	Justification
Criticité	Critique (P1)	Export complet d'une table de données personnelles et bancaires ; risque 99/100 sur la règle EQL [P2]
Catégorie	Fuite de données / usage abusif d'un compte légitime	Compte valide, droits de lecture normaux, mais volume et export anormaux
Vrai ou faux positif	Vrai positif	600 lectures en rafale, puis un export dans la même seconde, même compte, même IP [P1]
MITRE ATT&CK	TA0009 Collection, TA0010 Exfiltration, T1530 (Data from Cloud Storage, adaptée ici à une base de données)	Mapping porté par les règles [P6]
Use case	Groupe 3 : exfiltration de données clients	Énoncé du projet

3. Chronologie

Heures de Paris (UTC+1). Les horodatages viennent des journaux indexés dans le SIEM et de l'historique du case.

Heure	Étape	Événement	Preuve
18:16:11.493	Premier événement	Première des 600 lectures SELECT sur core_clients.clients par c_dupont, depuis 10.0.5.10	P1
18:16:11.680	Exfiltration	COPY clients TO STDOUT : export complet de la table	P1
18:16:26	Détection	Alerte EQL « Lecture massive base clients puis export », critique, risque 99	P2
18:16:35	Détection	Alerte Threshold « Lecture massive base clients », élevée, risque 73	P2
18:17:13	Prise en charge auto	Case ouvert par le SOAR Shuffle, alertes attachées	P3

18:17:16	Containment	Rôle PostgreSQL c_dupont en NOLOGIN, sessions coupées	P4
18:17:17	Containment	Compte AD c.dupont désactivé (événement Windows 4725, auteur svc.shuffle)	P4
18:17:19	Acquittement	Alertes passées en « acknowledged », étiquette soar-traite	P3
21:38	Qualification	Analyste N1 : vrai positif confirmé, escalade N2 (triage différé de l'exercice)	P3
21:39:40	Clôture	Ticket 5W publié, case clos, alertes closes	P3

Indicateur	Valeur	Calcul
MTTD (délai de détection)	15 s	export 18:16:11.680 → alerte EQL 18:16:26
Délai de containment	50 s	alerte EQL 18:16:26 → rôle verrouillé 18:17:16
MTTR (prise en charge par le SOAR)	53 s	alerte EQL → acquittement 18:17:19

4. Portée et actifs impactés

Élément	Détail
Compte base	c_dupont, rôle PostgreSQL en lecture seule sur la table clients
Compte annuaire	AZURBANK\c.dupont, conseiller clientèle (OU Agences)
Système cible	db-clients-01 (10.10.1.20), PostgreSQL 17 + pgaudit, base core_clients, zone DC (systèmes critiques, à côté du CBS)
Point d'accès	bastion-01 (10.0.5.10), zone ADM : seul chemin autorisé vers la base par le pare-feu fw-01
Données	5 000 fiches clients : nom, IBAN, solde. Données personnelles et bancaires, sans numéro de carte (PAN)
Zones non touchées	DMZ (portail web) : aucune activité de c_dupont. Passerelle SWIFT : un case distinct « Virement SWIFT anormal - opérateur c.dupont » existe le même jour (tests du simulateur dans l'après-midi) ; même titulaire, à rapprocher par le N2, sans lien technique avec l'export [P5]
Autres comptes	Aucun : sur 24 h, c_dupont est le seul compte à avoir lu la table clients [P5]

5. Analyse technique

5.1 Collecte et normalisation

pgaudit journalise chaque requête sur la base. L'Elastic Agent de db-clients-01 collecte ces lignes, et l'ingest pipeline db-audit-pgaudit les découpe en champs ECS (event.action, object, user.name, source.ip, db.statement). Le résultat est indexé dans logs-db.audit-default [P7].

5.2 Règles déclenchées

Règle	Format	Logique	Alerte
Lecture massive base clients puis export	EQL (natif) + Sigma	sequence by user.name, maxspan 10 min : 100 lectures de clients puis un export	18:16:26, critique, 99
Lecture massive base clients	Threshold KQL (natif) + Sigma	≥ 500 lectures de clients par user.name en 10 min	18:16:35, élevée, 73
Lecture massive puis export (ES|QL)	ES|QL (natif)	> 500 lectures et ≥ 1 export, l'export après les lectures	18:17:17, critique, 99

5.3 Preuves

Requête de vérification (KQL, Discover) :

event.dataset : "db.audit" and user.name : "c_dupont" and event.action : ("select" or "export")

Sur 18:10 - 18:25 : 600 select (de 18:16:11.493 à 18:16:11.638, soit 145 ms), 1 export à 18:16:11.680, tous depuis 10.0.5.10 [P1].

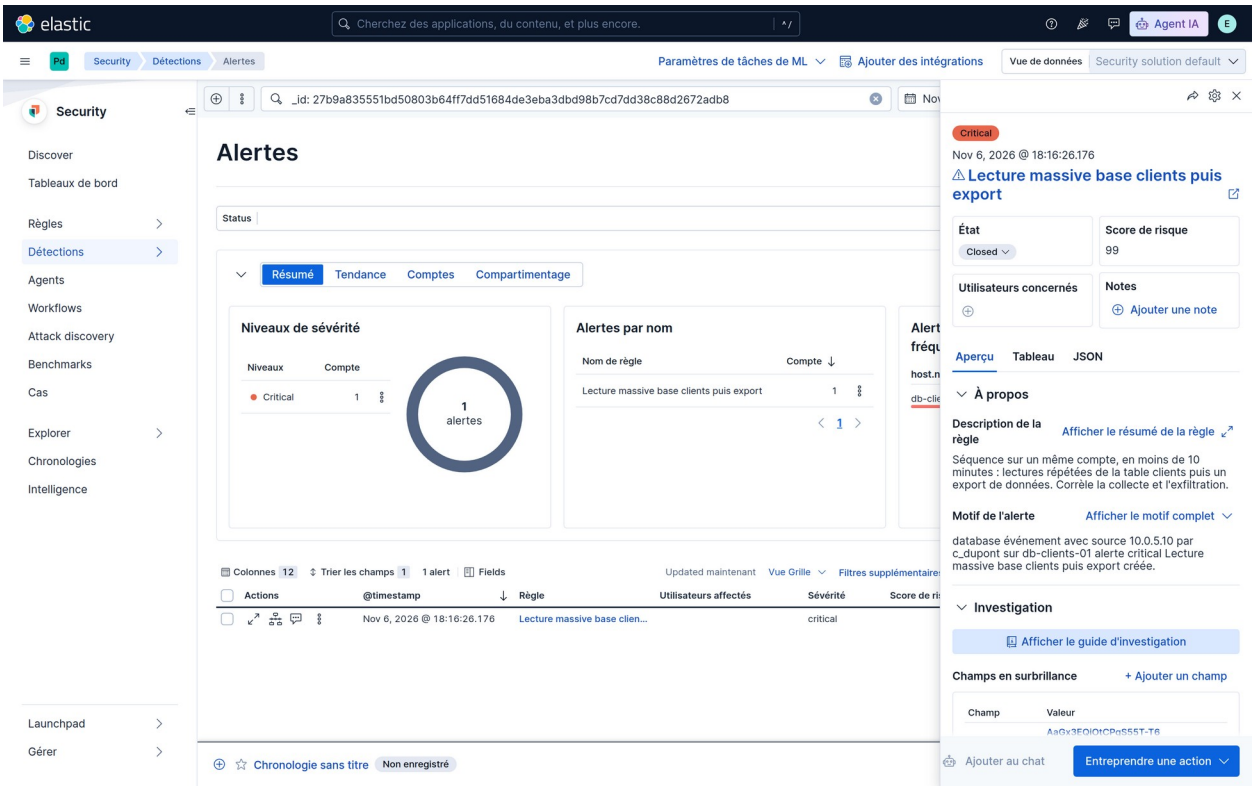


Figure 1. Alerte EQL dans Security > Alertes, motif « c_dupont depuis 10.0.5.10 sur db-clients-01 » [P2]

5.4 Indicateurs relevés (IOC)

Type	Valeur	Commentaire
Compte	c_dupont / AZURBANK\c.dupont	compte légitime détourné ou utilisé abusivement
IP source	10.0.5.10 (bastion-01)	interne : pivot d'administration, pas une IP d'attaquant
Requête	COPY clients TO STDOUT	export complet, jamais utilisé par un conseiller en temps normal
Comportement	600 SELECT unitaires en 145 ms	rafale scriptée, pas une consultation humaine

6. Réponse

Phase	Action	Automatisé (SOAR) ou humain
Containment	Rôle c_dupont en NOLOGIN, sessions PostgreSQL coupées (script soar-verrou-db.sh sur db-clients-01)	Automatisé, 18:17:16 [P4]
Containment	Compte AD c.dupont désactivé (Disable-ADAccount par svc.shuffle)	Automatisé, 18:17:17 [P4]
Containment	Blocage d'IP sur fw-01 (alias BLOCKLIST_SOAR)	Non appliqué par le playbook : IP interne (bastion), garde-fou voulu
Coordination	Case Kibana, alertes attachées puis acquittées, bilan des actions en commentaire	Automatisé, 18:17:13 à 18:17:19 [P3]
Qualification	Vérification des alertes, vrai positif, alerte ES|QL rattachée, case en double fermé	Humain (N1)
Éradication	Analyse du bastion : fichier écrit, rebond vers l'extérieur, autres sessions de c_dupont	Humain (N2), à mener
Remédiation	Changement du mot de passe, TOTP imposé, droits de c_dupont réduits (vue par agence, pas de COPY)	Humain, validation RSSI
Retour à la	Compte réactivé après remédiation (dans l'exercice : 18:20:51,	Humain [P4]

normale	événement 4722)	

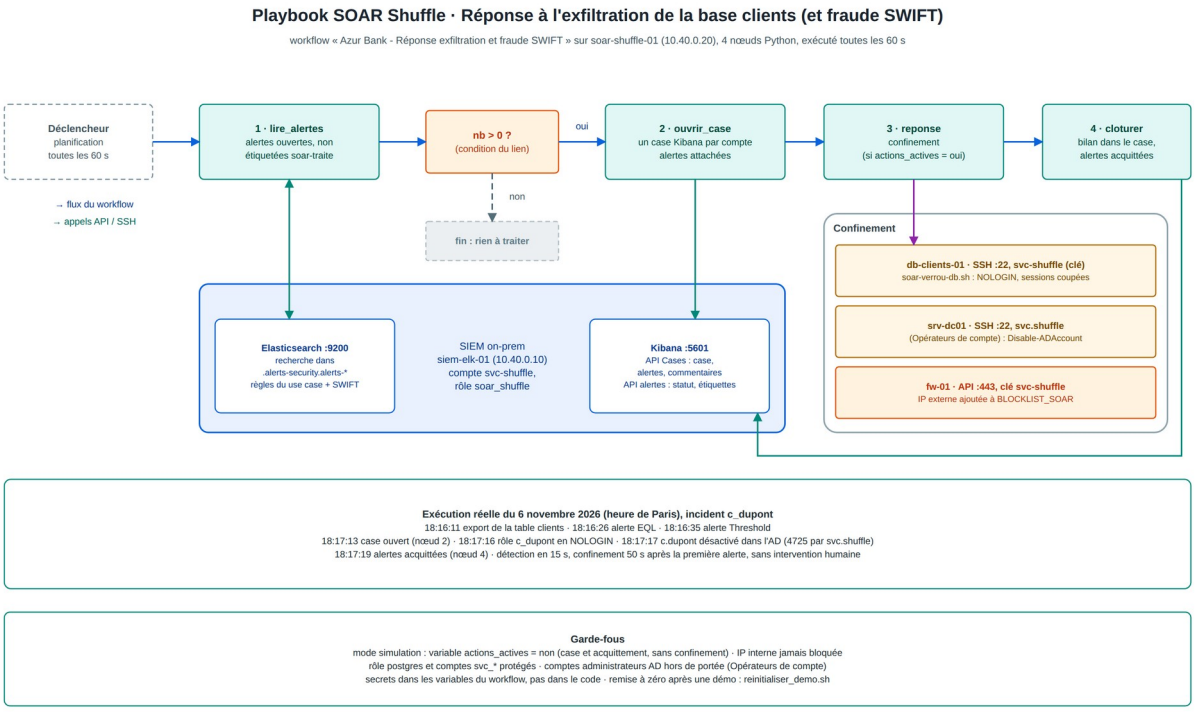


Figure 2. Playbook Shuffle exécuté : 4 nœuds, garde-fous et temps mesurés [P3]

Part automatisée : la détection, l'ouverture du case, le confinement des deux comptes et l'acquittement, en moins d'une minute. Part humaine : la qualification, la décision de notifier, l'éradication et la remise en service. Un mode simulation (actions_actives = non) permet de tester le playbook sans confinement.

7. Impact conformité

Référentiel	Obligation	Situation et preuves à conserver
RGPD (art. 33 et 34)	Notifier la CNIL sous 72 h si le risque pour les personnes est avéré ; informer les clients si le risque est élevé	IBAN et identité de 5 000 clients exportés : notification à décider par le DPO avant le 9/11, 18:16
PCI DSS v4.0.1	10.2 journaliser les accès aux données ; 10.5.1 conserver 12 mois (3 en ligne) ; 12.10 plan de réponse	Pas de PAN dans la table : hors périmètre carte. Journaux, alertes et case conservés 12 mois
SWIFT CSP	Surveiller et tracer l'environnement SWIFT (contrôle 6.4)	Pas d'accès à la passerelle SWIFT dans cet incident. Le case SWIFT du même jour, au nom de c.dupont, est suivi à part
SEPA / DSP2	Protéger les données de paiement et prévenir la fraude	IBAN exposés : risque de fraude au faux conseiller, surveillance renforcée des virements
DORA	Classer l'incident TIC, le notifier à l'ACPR s'il est majeur	Classification à faire par le RSSI (nombre de clients, données, réputation)

Preuves archivées : l'export du case Kibana (commentaires, alertes, historique), les documents logs-db.audit-* de 18:16, les événements 4725 et 4722 de srv-dc01, l'historique d'exécution Shuffle et ce rapport.

8. Recommandations et leçons apprises

Ce qui a fonctionné

- Trois écritures de la même détection (EQL, Threshold, ES|QL) : l'incident est vu par trois règles indépendantes.
- Confinement en 50 s par des comptes de service aux droits minimaux, avec des garde-fous (IP interne jamais bloquée, rôle postgres protégé).

À améliorer

- Règles : ajouter une règle « COPY TO par un rôle conseiller » (un seul événement suffit, sans seuil), et une exception nominative pour les comptes de service batch afin de réduire les faux positifs.
- SOAR : rattacher automatiquement une alerte tardive au case ouvert au lieu d'en créer un second (corrigé dans le playbook : réutilisation du case ouvert du même compte).
- Bastion : imposer le TOTP à tous les comptes (retirer nullok de pam_google_authenticator).
- Base : vue restreinte aux clients de l'agence du conseiller, retrait du droit COPY, plafond de lignes par requête.
- Traçabilité : journaliser les fichiers écrits sur le bastion (auditd) pour suivre une donnée exportée.
- Exercice : rejouer ce scénario chaque trimestre et mesurer MTTD et délai de containment dans le dashboard COMEX.

Risque résiduel

Moyen : les données ont quitté la base et se trouvent sur le bastion. Tant que leur devenir n'est pas tracé, une fuite hors de la banque ne peut pas être exclue.

Preuves (sources)

Réf.	Preuve	Où la trouver
P1	Événements pgaudit de c_dupont, 18:10 - 18:25 (600 select, 1 export, source 10.0.5.10)	SIEM, logs-db.audit-default ; requête du § 5.3
P2	Alertes EQL, Threshold et ES|QL avec horodatage, sévérité et score	Security > Alertes ; captures 03/captures/alerte-exfiltration-c_dupont.png
P3	Case Kibana : création, alertes attachées, commentaires du SOAR et des analystes, clôture	Security > Cas ; capture 04/schemas/case-kibana-c_dupont.png ; historique d'exécution Shuffle
P4	Verrouillage du rôle (journal « soar » de db-clients-01), événements Windows 4725 et 4722 sur srv-dc01	SIEM, logs-system.syslog-* et logs-system.security-*
P5	Lecteurs de la table clients sur 24 h ; flux sortants de db-clients-01 dans les journaux de fw-01	SIEM, logs-db.audit-* et logs-pfsense.log-*
P6	Définition des règles et mapping MITRE	03/regles/elastic-basic/, 03/regles/sigma/, captures 03/captures/regle-*.png
P7	Pipeline d'ingestion pgaudit et politique Fleet	02/infra/pipeline_db_audit_pgaudit.json, 02/infra/creer_politiques.py